- **Vérifier la légitimité des utilisateurs** du système lorsque celui-ci est rendu disponible en tant que service, afin d'éviter une tentative d'attaque telle qu'une **attaque par inversion de modèle**[126] **ou par déni de service**.
- **Prévoir un plan d'audit du système**, portant sur les éléments logiciels, matériels, et sur les mesures organisationnelles telles que **les procédures de supervision humaine du système d'IA**.

Ce qu'il ne faut pas faire

- Entraîner un modèle sur des données **dont la source est inconnue ou n'est pas fiable, ou dont la qualité, et notamment celle de l'annotation, n'a pas été vérifiée**.
- Déployer, partager, diffuser ou rendre accessible un modèle **sans vérifier la qualité des sorties**, et en particulier **l'absence de sorties problématiques** (ex : contenus haineux) **et de données personnelles**, hormis à des fins de tests et d'audit.
- Utiliser un système **sans en connaître les limitations**, ou **sans évaluer les conséquences d'une erreur ou d'un biais**.

POUR ALLER PLUS LOIN

- La CNIL a publié un ensemble de fiches[127] concernant la phase de développement des systèmes d'IA impliquant des données personnelles.
- Les modèles d'attaques sur les systèmes d'IA sont divers et encore peu connus. Le Laboratoire d'innovation numérique de la CNIL (LINC) a publié un premier article recensant ces attaques[128] ainsi qu'un second recensant les bonnes pratiques de sécurité pour s'en prémunir[129] (comme l'apprentissage fédéré, ou la confidentialité différentielle).
- La collecte de données personnelles peut être minimisée grâce à des techniques d'augmentation ou de synthèse de données, ou encore en concentrant la collecte sur des données de qualité.
- Les données utilisées lors de la phase de déploiement peuvent évoluer au cours du temps, et perdre en qualité pour plusieurs raisons (ex. : détérioration d'un capteur, dérive ou empoisonnement des données). Ces évolutions doivent être surveillées.
- Le résultat fourni par le système peut être accompagné d'informations permettant à l'utilisateur de l'interpréter et d'identifier une éventuelle erreur (ex. : score de confiance, carte de saillance).
- Des mesures, telles que des filtres sur les sorties, l'apprentissage par renforcement à partir de la rétroaction humaine (« *reinforcement learning from human Feedback* » ou RLHF) ou encore le tatouage numérique (« *watermarking* ») du contenu généré, permettent de sécuriser les contenus produits par le système.

127 « Les fiches pratiques IA », cnil.fr

128 « Petite taxonomie des attaques des systèmes d'IA », linc.cnil.fr

129 « Sécurité des systèmes d'IA, les gestes qui sauvent », linc.cnil.fr